

Guia practica - Arquetipos de rooms THM / CTF

Uso previsto: laboratorios autorizados, TryHackMe y CTF. Ajusta rutas, IPs, credenciales y herramientas segun el entorno.

Objetivo

Guia corta para identificar el patron dominante de una room y no perder tiempo saltando entre comandos sin hipotesis.

Un arquetipo no sustituye la enumeracion: la ordena. Si una room mezcla varios patrones, prioriza el que te de identidad, credenciales o shell inicial.

1. Tabla de arquetipos

Arquetipo	Señales	Ruta recomendada
Web basica	80/443, login, rutas ocultas, uploads.	Discovery -> Burp -> LFI/SSTI/upload/IDOR/creds.
WordPress/CMS	wp-content, wp-login, plugins, temas.	WPScan -> usuarios -> plugins/temas -> creds/wp-admin -> RCE.
SQLi room	Parametros, errores SQL, login bypass.	Confirmar manual -> sqlmap con request -> dump -> hashes/RCE si aplica.
SMB/Linux mixta	445, shares, backups, usuarios reutilizables.	Shares -> loot -> cred reuse -> SSH/web/sudo.
Active Directory	53/88/389/445, dominio, DC.	Hosts/DNS -> usuarios -> spraying controlado -> Kerberos/BloodHound.
Linux privesc	Shell Linux sin root.	id/sudo -l -> SUID -> caps -> cron/systemd -> creds.
Windows privesc	Shell Windows sin admin.	whoami /priv -> servicios -> tareas -> registry -> creds.
Pivoting	Servicios localhost o red interna no accesible.	Rutas/interfaces -> ssh -L/-D, chisel o ligolo -> reenum interna.
Cracking/loot	Hashes, kdbx, id_rsa, zips, backups.	Convertir con *2john -> crackear -> cred reuse controlado.
CVE/exploit	Version concreta vulnerable.	Verificar version/config -> leer PoC -> check -> payload minimo.

2. Como decidir

- Elige el arquetipo por evidencia: puertos, rutas, banners, usuarios, archivos o permisos.
- Si aparece una credencial valida, reenumera antes de seguir explotando.
- Si hay web y SMB a la vez, busca credenciales cruzadas: backups web en shares, usuarios de dominio en paneles, configs con DB creds.
- Si tienes shell pero no avance, cambia a post-exploit/privesc. No sigas fuzzing externo por inercia.
- Si no hay progreso en 20-30 minutos, usa la checklist de atasco.

3. Atajos mentales

Si el primer hallazgo es...	Piensa primero en...
Usuarios reales	Password spraying controlado, usuario=password, AS-REP/Kerberoast en AD.

Si el primer hallazgo es...	Piensa primero en...
Backup o config	Credenciales, rutas internas, DB, reutilizacion en SSH/SMB/web.
Upload	Extension, Content-Type, magic bytes, ruta de ejecucion.
Servicio localhost	Port forward o pivot antes de enumerar mas fuera.
Version vulnerable	Confirmar version/config y leer PoC antes de ejecutar.
Shell limitada	Estabilizar, transferir herramientas y enumerar local.